

Mapeo detallado GQM + PRAGMATIC a requisitos normativos

Tabla orientativa que conecta objetivos y métricas FAIR-STRIDE (estructurados con GQM y evaluados con PRAGMATIC) con principales marcos normativos (ISO 27001/27005, NIST CSF/RMF, NIS2, DORA).

Dimensión FAIR-STRIDE	Ejemplo de Goal GQM	Métricas clave asociadas (ejemplos)	ISO 27001 / 27005	NIST CSF / RMF	NIS2 / DORA / UE
Autenticidad	Reducir la pérdida anual esperada por suplantación de identidad en servicios esenciales	Nº incidentes suplantación (A1); Pérdida anual esperada FAIR (A2); % MFA (A3)	Cláus. 6.1, A.5.15, A.5.17, A.8.2	ID.RA, PR.AC-1/6, PR.IP-12	NIS2 Art. 21; requisitos de autenticación fuerte en sectores regulados
Integridad	Minimizar la pérdida anual esperada por alteraciones de integridad en datos críticos	Nº incidentes integridad (I1); MTTD/MTTR integridad (I2); Pérdida FAIR (I3)	A.5.10, A.8.9, ISO 27005 (identificación y análisis)	PR.DS-6/7, DE.CM-7, RC.IM-1	NIS2: integridad de redes y sistemas; requisitos de registro y trazabilidad
No repudio	Reducir exposición a pérdidas por disputas y fraudes por falta de evidencia	% procesos críticos con no repudio (NR1); Nº/coste disputas (NR2)	A.8.11, A.8.15	PR.PT-1, PR.DS-1	DORA: evidencias de transacciones financieras; NIS2: obligación de registro
Confidencialidad	Disminuir la pérdida anual esperada por brechas de confidencialidad	Nº brechas datos (C1); Pérdida FAIR (C2); % cifrado datos sensibles (C3)	A.5.10, A.5.12, A.8.24, ISO 27005	PR.DS-1/5, DE.CM-1, RS.AN-1	NIS2, RGPD: protección de datos, brechas y notificación
Disponibilidad	Limitar pérdida anual esperada por indisponibilidad de servicios críticos	Horas caída (D1); Pérdida FAIR (D2); % cumplimiento RTO/RPO (D3)	Cláus. 6.1, A.5.30, A.5.31, A.8.14, A.8.16	ID.BE-5, PR.IP-9, RC.RP-1	NIS2: continuidad de servicios esenciales; DORA: resiliencia operativa digital
Autorización	Reducir pérdida anual esperada por abusos de privilegios y accesos indebidos	Nº incidentes abuso privilegios (AU1); % cuentas en PAM (AU2); Pérdida FAIR (AU3)	A.5.15, A.8.2, A.8.3	PR.AC-4/5, DE.CM-3	NIS2: gestión de accesos y privilegios; DORA: control de acceso en entidades financieras

Arquitectura / Zero Trust	Incrementar resiliencia mediante segmentación, verificación continua y mínimo privilegio	% segmentación ZT desplegada; nº flujos críticos modelados con STRIDE; reducción pérdida FAIR asociada	A.5.7, A.5.19, A.8.23	PR.AC, PR.PT-3/4, DE.CM-7	NIS2: seguridad de redes y sistemas; guías europeas de Zero Trust
Resiliencia / Continuidad	Mejorar capacidad de recuperación frente a incidentes cibernéticos de alta severidad	Cumplimiento RTO/RPO; nº ejercicios de crisis; ROI de inversiones de continuidad	Cláus. 6.1, A.5.30-32, ISO 22301 (si aplica)	PR.IP-9, RC.IM-1/2	NIS2 Art. 21; DORA: pruebas de resiliencia avanzada
Datos y gobierno	Fortalecer calidad y gobernanza de datos de incidentes y riesgos	Calidad datos incidentes; existencia repositorio central; responsable de gobierno	A.5.8, A.5.36, A.8.16	ID.GV, DE.AE-3, RS.AN	NIS2: reporte de incidentes y supervisión; DORA: reporting
Cultura y talento	Aumentar capacidades en cuantificación FAIR y modelado STRIDE en todo el ecosistema	Nº perfiles FAIR; nivel de formación; uso de métricas en comités de riesgo	Cláus. 7 (competencia, toma de conciencia)	ID.GV, PR.AT-1/2	NIS2/DORA: gobernanza, responsabilidades de dirección

Cada métrica definida en el marco GQM se puede anotar en una tabla adicional, con columnas:

- Código métrica (p. ej., C2, D3, AU2).
- Goal GQM al que contribuye.
- Criterios PRAGMATIC (scores).
- Referencias normativas específicas (artículos, controles).
- Uso en informes nacionales, sectoriales, organizativos.